

HIPAA Compliance

The Complete Guide — Privacy, Security & Breach Notification Rules

Presentation deck · 2026

For engineering, product, security & compliance teams

Agenda — 26 slides

1. What is HIPAA
2. History & timeline
3. Who must comply — Covered Entities
4. Who must comply — Business Associates
5. What is PHI
6. The 18 Safe Harbor identifiers
7. The three HIPAA rules
8. Privacy Rule — overview
9. Privacy Rule — patient rights
10. Security Rule — overview
11. Administrative Safeguards
12. Physical Safeguards
13. Technical Safeguards
14. Required vs Addressable
15. Breach Notification Rule
16. Business Associate Agreements (BAA)
17. Minimum Necessary Standard
18. De-identification methods
19. Penalties & enforcement
20. Real-world breach examples
21. Common violations
22. Implementation checklist
23. HIPAA vs other regulations
24. State-specific addenda
25. Key references
26. Q&A

What is HIPAA?

Health Insurance Portability and Accountability Act — US federal law signed 1996 that protects sensitive patient health information from disclosure without consent.

Two main goals

1. **Portability** — workers keep health insurance when changing jobs
2. **Accountability** — set national standards for protecting health information

Why it matters today

- Healthcare data breaches cost **\$10.93M average** (IBM 2023 report) — highest of any industry
- OCR enforcement up **250%** over last decade
- Cyber attacks on healthcare up **74%** in 2023
- Every state has additional health-data laws stacking on top

Quick definition

HIPAA = the rules every entity touching protected health information (PHI) must follow.

If you handle health data of US patients, HIPAA applies — even if your company is foreign.

Enforced by

- **HHS Office for Civil Rights (OCR)** — federal enforcement
- **State Attorneys General** — can sue independently
- **Department of Justice** — criminal cases

History & timeline

- 
- 1996** **HIPAA enacted** by Congress. Initially focused on insurance portability.
 - 2003** **Privacy Rule** finalized. Sets standards for use and disclosure of PHI.
 - 2005** **Security Rule** finalized. Sets standards for electronic PHI (ePHI).
 - 2009** **HITECH Act** expanded HIPAA — added breach notification, increased penalties, extended to Business Associates directly.
 - 2013** **Omnibus Final Rule** — strengthened BAA requirements, broadened "breach" definition (burden of proof shifted to covered entity).
 - 2024** **Tracking Technologies Bulletin** (Dec) — OCR clarified Google Analytics / Meta Pixel on patient pages = HIPAA violation.
 - 2024** **NIST 800-66 Rev 2** published — current implementation guide for the Security Rule.
 - 2025** **HIPAA Security Rule NPRM** proposed — mandatory MFA, encryption, vulnerability scans, network segmentation. Expected finalization 2026–2027.

Who must comply — Covered Entities

HIPAA directly binds **Covered Entities (CEs)** — three categories defined by law.

1. Healthcare Providers

Any provider who transmits health info electronically in connection with a HIPAA-defined transaction.

- Hospitals, clinics
- Physicians, dentists, chiropractors
- Pharmacies
- Mental health providers
- Nursing homes
- Home health agencies

2. Health Plans

Entity that provides or pays for medical care.

- Health insurance companies
- HMOs
- Employer-sponsored group plans
- Government plans (Medicare, Medicaid, VA)
- Dental, vision, prescription drug plans

3. Healthcare Clearinghouses

Entities that process health info between providers and payers.

- Billing services
- Repricing companies
- Community health management info systems

Less common; included for completeness.

Not covered by HIPAA

Life insurance, workers' comp, employer health records (employment use), most fitness/wellness apps, consumer DNA tests. They have other laws (FTC Act, state laws, GDPR).

Who must comply — Business Associates

Business Associate (BA) = any person or entity performing services for a Covered Entity that involves use or disclosure of PHI.

Examples of Business Associates

- Cloud hosting providers (AWS, GCP, Azure)
- SaaS platforms processing patient data
- Software developers building EHR systems
- Email services (Mailgun, SendGrid)
- Error monitoring (Sentry, Datadog) — Enterprise tier
- Billing & claims processing
- Lawyers, accountants, consultants with PHI access
- Medical transcription services
- Records storage / shredding companies
- Subcontractors of any BA (cascade)

HITECH 2009 expansion

Before HITECH, only Covered Entities could be fined. Now **BAs are directly liable to OCR** for HIPAA violations — same penalty tiers as CEs. Subcontractors of BAs also liable. The "BAA chain" can go 3+ levels deep.

If you build healthcare software

You are **almost certainly** a Business Associate. You need a signed BAA with every Covered Entity client AND every subprocessor you use that touches PHI. **No BAA + PHI flow = automatic violation.**

What is PHI?

Protected Health Information (PHI) = any information about health status, healthcare, or payment for healthcare that **can be linked to an individual**.

The formula

PHI = Health Information + Identifier

Either alone is not PHI. Combined, it is.

Examples of PHI

- Patient's name + diagnosis
- Email + prescription
- Phone number + appointment date
- Photo of patient + medical record
- IP address + visit to clinic website
- Insurance ID + treatment claim

ePHI (electronic PHI)

PHI created, stored, transmitted, or maintained electronically. **Security Rule applies specifically to ePHI.**

- EHR / EMR records
- Lab results in databases
- Emails containing patient info
- SMS, push notifications, app data
- Backup tapes, cloud storage
- Logs that capture PHI

Designated Record Set (DRS)

The complete set of medical/billing records about a patient — what patients have right to access.

The 18 Safe Harbor identifiers

Per 45 CFR § 164.514(b)(2). Remove ALL 18 → data is de-identified → HIPAA no longer applies.

1. Names
2. Geographic info smaller than state (street, city, county, ZIP)
3. Dates except year (birth, admission, discharge, death, service)
4. Phone numbers
5. Fax numbers
6. Email addresses
7. Social Security numbers
8. Medical record numbers (MRN)
9. Health plan beneficiary numbers
10. Account numbers
11. Certificate / license numbers
12. Vehicle identifiers (license plates, VIN)
13. Device identifiers and serial numbers
14. Web URLs identifying individuals
15. IP addresses
16. Biometric identifiers (fingerprints, voiceprints, retinal scans)
17. Full-face photographs and comparable images
18. Any other unique identifying number, characteristic, or code

Common gotchas

- **Black bars over eyes ≠ sufficient** — full face means face anatomy, not just identifying gaze
- **For patients > 89**, year must be aggregated to "90+" — birth year reveals age
- **Rare disease + ZIP + age** can re-identify even without name (statistical disclosure)
- **Initials are identifiers** in small populations

The Three Rules

Privacy · Security · Breach Notification

Privacy Rule — overview

Effective 2003. Sets national standards for **use and disclosure** of PHI in any form (paper, oral, electronic).

Core principle: Minimum Necessary

When using or disclosing PHI, limit to the **minimum** needed for the purpose.

Does NOT apply to:

- Treatment (providers may need everything)
- Patient-authorized disclosures
- Disclosures to the patient themselves
- Required by law (subpoenas, public health)
- HHS compliance investigations

Permitted uses without authorization (TPO)

1. **T**reatment — providing care
2. **P**ayment — billing, claims
3. **O**perations — quality assessment, training, audits

Requires written authorization

- Research (unless IRB waiver)
- Marketing
- Sale of PHI
- Psychotherapy notes
- Any use beyond TPO

Notice of Privacy Practices (NPP)

Every Covered Entity must publish a written notice describing how PHI is used, patient rights, and how to file complaints. Posted on website + given to patients at first encounter.

Privacy Rule — patient rights

Six rights every patient has under HIPAA. Covered Entities must support all six.

1. Right of Access

Get a copy of their PHI in the requested format **within 30 days**.
Electronic copy must be in machine-readable format.

2. Right to Amend

Request corrections to PHI they believe is inaccurate or incomplete. CE can deny but must give reason.

3. Accounting of Disclosures

Get a list of every non-TPO disclosure of their PHI in the past 6 years.

4. Request Restrictions

Ask CE to limit use/disclosure (e.g., don't share with specific family member). CE may decline except for self-pay-only restriction.

5. Confidential Communications

Receive PHI via alternative means (work address vs home, alternate phone).

6. File Complaints

Complain to the CE or directly to HHS OCR — without retaliation.

Cite: 45 CFR § 164.520–528

Security Rule — overview

Effective 2005. Sets national standards for protecting **electronic PHI (ePHI)**. Does not apply to paper or oral PHI (Privacy Rule covers those).

Three principles

Confidentiality

ePHI not available to unauthorized people or processes.

Integrity

ePHI not altered or destroyed without authorization.

Availability

ePHI accessible to authorized people when needed.

Three categories of safeguards

Administrative

People + policies — workforce training, access management, risk analysis, incident response, BAAs.

Physical

Buildings + devices — facility access, workstation policies, device disposal.

Technical

Software — access controls, audit logs, integrity controls, transmission security (encryption).

Cite: 45 CFR §§ 164.302–318. Implementation guide: NIST 800-66 Rev 2 (2024).

Administrative Safeguards

The largest safeguard category. People + processes.

STANDARD	IMPLEMENTATION SPECS	TYPE
Security Management Process	Risk analysis, risk management, sanction policy, info system activity review	REQUIRED
Assigned Security Responsibility	Designated Security Officer in writing	REQUIRED
Workforce Security	Authorization, supervision, workforce clearance, termination procedures	ADDRESSABLE
Information Access Management	Isolating clearinghouse, access authorization, access establishment / modification	ADDRESSABLE
Security Awareness and Training	Security reminders, malware protection, login monitoring, password management	ADDRESSABLE
Security Incident Procedures	Response and reporting	REQUIRED
Contingency Plan	Data backup, disaster recovery, emergency mode operation, testing & revision, app/data criticality analysis	REQUIRED
Evaluation	Periodic technical and non-technical evaluation of security posture	REQUIRED
BAA & Other Arrangements	Written contract or other arrangement with each BA	REQUIRED

Cite: 45 CFR § 164.308

Physical Safeguards

Protect ePHI in physical form — facilities, workstations, devices.

STANDARD	IMPLEMENTATION SPECS	TYPE
Facility Access Controls	Contingency operations, facility security plan, access control & validation procedures, maintenance records	ADDRESSABLE
Workstation Use	Policies for proper functions, manner, and physical attributes of workstations accessing ePHI	REQUIRED
Workstation Security	Physical safeguards for all workstations accessing ePHI	REQUIRED
Device and Media Controls	Disposal, media re-use, accountability, data backup & storage	REQUIRED

Modern interpretation

- Office access cards / visitor logs
- Server room locks + cameras
- Screen privacy filters
- Auto-lock workstations after idle
- Encrypted laptops with MDM enrollment
- BYOD policy with remote wipe
- Secure disposal of hard drives (NIST 800-88)
- Work-from-home workstation policy
- Media inventory (USB, tapes, paper records)
- Cloud provider's physical security inherited via BAA

Cite: 45 CFR § 164.310

Technical Safeguards

What engineers usually mean when they say "HIPAA compliant code."

STANDARD	IMPLEMENTATION SPECS	TYPE
Access Control	Unique user identification	REQUIRED
	Emergency access procedure	REQUIRED
	Automatic logoff	ADDRESSABLE
	Encryption & decryption of ePHI at rest	ADDRESSABLE
Audit Controls	Hardware, software, procedural mechanisms recording activity in systems with ePHI	REQUIRED
Integrity	Mechanisms to authenticate ePHI (ensure not altered or destroyed)	ADDRESSABLE
Person or Entity Authentication	Verify identity of person/entity seeking access	REQUIRED
Transmission Security	Integrity controls + encryption in transit (TLS 1.2+)	ADDRESSABLE

"Addressable" is not optional

Addressable means: implement it, OR document a reasonable equivalent. You cannot skip it. OCR specifically asks about addressable controls in audits — "we decided not to" is not a valid answer.

Cite: 45 CFR § 164.312

Required vs Addressable

Every Security Rule implementation spec is labeled **Required** or **Addressable**. Misunderstanding this is the most common HIPAA error.

REQUIRED Required

Mandatory. Must implement exactly as specified. No alternatives accepted.

Example: Unique user identification, audit controls, BAAs.

ADDRESSABLE Addressable

Not optional. Must either:

1. Implement the specification as stated, OR
2. Implement a documented equivalent that achieves the same security objective, OR
3. Document a reasoned explanation of why no implementation is needed (rare and risky)

Example: Encryption at rest, automatic logoff, integrity controls.

Best practice

Treat all addressable specs as required unless you have written, dated, signed justification for an alternative. Document the reasoning in your risk analysis. OCR sees "addressable" as a soft "do this anyway."

Cite: 45 CFR § 164.306(d)(3)

Breach Notification Rule

Effective 2009 (HITECH). Defines what counts as a breach and what to do when one occurs.

What counts as a breach?

Acquisition, access, use, or disclosure of PHI **not permitted** by the Privacy Rule that compromises security or privacy.

4-Factor Risk Assessment

1. Nature and extent of PHI involved
2. Who accessed or received the PHI
3. Whether PHI was actually acquired or viewed
4. Extent to which risk has been mitigated

Burden of proof is on you — default = breach.

Safe Harbor exception

If ePHI was encrypted per NIST standards **and** the encryption key was not compromised → not a reportable breach.

This is why encryption is the #1 control.

Notification requirements

SCOPE	AFFECTED INDIVIDUALS	HHS	MEDIA
< 500 individuals	Within 60 days	Annually (by Feb 28 next year)	Not required
≥ 500 individuals	Within 60 days	Within 60 days	Prominent media outlets in the affected state/jurisdiction within 60 days

Cite: 45 CFR §§ 164.400–414

Business Associate Agreements (BAA)

BAA = the legal contract binding a Business Associate to HIPAA obligations. Without it, sharing PHI with a vendor = automatic violation.

A BAA must require the BA to

- Use PHI only for the purpose stated
- Implement appropriate safeguards
- Report breaches to the Covered Entity
- Pass HIPAA obligations to its own subcontractors via BAAs
- Make PHI available to individuals exercising rights
- Make books and records available to HHS for audit
- Return or destroy PHI at contract termination
- Use safeguards equivalent to Security Rule
- Notify CE of unauthorized use/disclosure
- Be directly liable to OCR (post-HITECH)

Vendor BAA reality (2026)

Will sign BAA

- AWS, GCP, Azure
- Stripe, Twilio, SendGrid
- Auth0, Okta, Clerk
- Salesforce Health Cloud

Enterprise tier only

- Sentry, Datadog
- Vercel, Netlify
- Cloudflare
- HubSpot, Intercom

Will NOT sign — replace

- Google Analytics, Meta Pixel
- Mailchimp, Postmark
- Slack standard
- Mixpanel, standard Heap

The Minimum Necessary Standard

Use, disclose, and request only the **minimum amount of PHI** needed to accomplish the intended purpose.

How it shows up in software

- **RBAC, not "all read"**: nurses don't see billing data; billing doesn't see clinical notes
- **API responses trim PHI**: only return fields needed for the page/view
- **Logs scrub PHI**: log user_id, not patient_name + diagnosis
- **Search excludes PHI columns** unless authorized
- **Reports aggregate before exporting**
- **Mobile push titles don't include diagnosis**

Exceptions (minimum necessary does NOT apply)

- Disclosures to providers **for treatment**
- Disclosures **to the individual** themselves
- Disclosures with **patient authorization**
- Disclosures **required by law**
- Disclosures to **HHS for compliance review**

Engineer rule of thumb

If you can't justify why this field/row/column needs to be visible to this user, it shouldn't be.

Cite: 45 CFR § 164.502(b), § 164.514(d)

De-identification methods

Two methods to convert PHI into non-PHI data. Once de-identified, HIPAA no longer applies.

Method 1: Safe Harbor

How: Remove all 18 identifiers (see slide 8).

Plus: Have no actual knowledge that remaining info could identify individual.

Pros: Mechanical, easy to verify, well-documented.

Cons: Can destroy analytic utility (dates aggregated to year, geography to state).

Most common method. Recommended for most use cases.

Method 2: Expert Determination

How: Qualified statistician applies generally accepted statistical principles to determine "very small" risk of re-identification.

Plus: Document methodology, analysis, conclusion.

Pros: Can retain analytic detail (dates, geography).

Cons: Requires expert. Expensive. Methodology must be defensible.

Use for research datasets where temporal/spatial detail matters.

Bonus: Limited Data Set (LDS)

Removes 16 of 18 identifiers but may retain **dates** and **geographic info larger than street address**. Used for research / public health / operations. Requires a **Data Use Agreement (DUA)**, not full BAA.

Cite: 45 CFR § 164.514(b)–(e). HHS guidance: hhs.gov/hipaa/for-professionals/privacy/special-topics/de-identification

Penalties & enforcement

OCR investigates complaints and audits CEs / BAs. Penalties tiered by culpability. Updated annually for inflation.

TIER	CULPABILITY	PER VIOLATION	ANNUAL CAP
1	Did not know / could not have known	\$137 – \$68,928	\$2,067,813
2	Reasonable cause, not wilful neglect	\$1,379 – \$68,928	\$2,067,813
3	Wilful neglect — corrected within 30 days	\$13,785 – \$68,928	\$2,067,813
4	Wilful neglect — NOT corrected	\$68,928 – \$2,067,813	\$2,067,813

2024 figures. Each "violation" can be each record affected, each day continued.

Criminal penalties (DOJ enforcement)

OFFENSE	FINE	PRISON
Knowing violation	up to \$50,000	up to 1 year
Under false pretenses	up to \$100,000	up to 5 years
Intent to sell, transfer, or use for gain	up to \$250,000	up to 10 years

Cite: 42 USC § 1320d-5, § 1320d-6

Real-world breach examples

YEAR	ENTITY	CAUSE	PENALTY / IMPACT
2024	Change Healthcare (UnitedHealth subsidiary)	Ransomware via no-MFA Citrix portal	~190M records — largest healthcare breach ever. Multi-billion impact.
2024	Doctors Management Services	Ransomware — encrypted PHI exfiltrated	\$1.3M OCR settlement + corrective action plan
2023	HCA Healthcare	Insider data theft — 11M records	Multiple class action suits, ongoing investigation
2022–2024	Multiple hospitals (Novant Health, Advocate Aurora, others)	Meta Pixel on patient portals	Class action settlements totaling \$300M+
2022	Memorial Hermann Health System	Pixel tracking + ePHI to Meta	\$1.5M settlement
2020	Premiera Blue Cross	Phishing → APT → 10M records	\$6.85M OCR settlement
2018	Anthem	Phishing → credential reuse → 78.8M records	\$16M OCR settlement (largest)
2016	Advocate Health Care	4 unencrypted laptops stolen	\$5.55M settlement

Pattern

Top causes: (1) no MFA on remote access, (2) phishing leading to credential theft, (3) unencrypted endpoints, (4) third-party tracking pixels on patient pages, (5) insider misuse, (6) ransomware via unpatched edge.

Common violations (OCR top findings)

Technical

- Missing or weak encryption (at rest, in transit)
- No MFA on remote access
- Shared admin accounts
- Unrestricted database access (no RBAC)
- PHI in logs, URLs, push notifications
- Third-party trackers on patient pages
- Public cloud storage buckets
- Unpatched systems
- No audit logging or insufficient retention
- Unencrypted backups

Administrative / Process

- **No risk analysis** (or stale — top finding)
- No designated Security/Privacy Officer
- Workforce training missing or undocumented
- Missing or outdated BAAs
- No incident response plan
- No documented sanction policy
- Termination procedures not followed (ex-employees retain access)
- No access reviews
- Disposal policy missing or ignored
- Mailing PHI to wrong patient (top type by count)

The single most common finding

OCR cites **"failure to conduct an accurate and thorough risk analysis"** in roughly 60% of all enforcement cases. Every other gap flows from not having a current one.

Implementation checklist (CTO view)

Foundation — the five things that block everything else

1. **Risk Analysis** per NIST 800-30 — written, dated, reviewed annually
2. **BAAs inventoried + signed** — every CE client, every subprocessor
3. **Encryption at rest + in transit** — AES-256, TLS 1.2+, KMS keys
4. **Audit logs** — every PHI read/write, immutable, 6-year retention
5. **Privacy + Security Officers** designated in writing

Operational layer

- MFA on all workforce + admin accounts
- RBAC + minimum necessary access
- Unique user IDs (no shared accounts)
- Session timeout + auto-logout
- Workforce HIPAA training, annual, documented
- Sanction policy + termination procedure
- Incident response runbook + tabletop tested
- DR / contingency plan + tested
- Backups encrypted, offsite, restore-tested
- De-identification for dev/staging data
- Notice of Privacy Practices published
- Patient access request workflow (30-day SLA)

Audit-readiness layer

- Vendor BAA inventory + annual review
- Annual security evaluation (technical + non-technical)
- Penetration test annually
- Patch management policy
- Third-party SOC 2 or HITRUST audit (recommended)

HIPAA vs other regulations

REGULATION	JURISDICTION	COVERS	HIPAA RELATIONSHIP
HIPAA	US federal	PHI from covered entities	baseline
HITECH	US federal	Strengthens HIPAA + breach notification	part of HIPAA framework
42 CFR Part 2	US federal	Substance use disorder records	stricter than HIPAA — needs explicit consent
CCPA / CPRA	California	Consumer data, including some health info	parallel — HIPAA-covered data exempt
CMIA	California	Medical info	stricter than HIPAA — applies in addition
TX HB300	Texas	Health records	stricter training + breach requirements
NY SHIELD Act	New York	Private info incl. health	additional safeguards
GDPR	EU	Personal data of EU residents	different framework — health = special category
PIPEDA	Canada	Personal info	federal — provinces have their own (PHIPA, etc.)
FTC Act §5	US federal	Consumer health apps (non-HIPAA)	FTC enforces "Health Breach Notification" for apps

Stacking rule

When multiple laws apply, follow the **strictest one**. HIPAA preempts state laws only when state law is less protective. State law can always be stricter.

State-specific addenda (selected)

Many states layer additional rules on top of HIPAA. Selected examples:

STATE	LAW	KEY ADDITIONAL REQUIREMENTS
California	CMIA + CCPA + CPRA	Broader definition of medical info; 15-day breach notice (vs 60); private right of action
Texas	HB300 / TMRPA	Mandatory training within 90 days of hire + biennially; encryption required (no addressable); 60-day breach notice
New York	SHIELD Act	Reasonable safeguards mandatory; covers any business with NY residents' data
Florida	FIPA	30-day breach notification (vs 60); AG must be notified
Illinois	PIPA, BIPA	Biometric info has consent requirements; substantial damages
Connecticut	Data Privacy Act	90-day notice + identity theft protection offer
Massachusetts	201 CMR 17.00	Written information security program (WISP) required
Washington	My Health My Data Act	Non-HIPAA health data — broad consent + right to delete

Operating across states

If you serve patients in multiple states, the strictest combined rule applies. Don't assume HIPAA is enough — many startups have been fined under state laws while being "HIPAA compliant."

Key references & further reading

Primary sources (cite these in audits)

- **45 CFR Parts 160, 162, 164** — the actual federal regulation
- **HHS HIPAA portal:** hhs.gov/hipaa
- **NIST 800-66 Rev 2 (2024)** — HIPAA Security Rule implementation guide
- **NIST 800-30 Rev 1** — risk assessment methodology
- **NIST 800-66B** — guide for small/medium covered entities
- **NIST 800-52 Rev 2** — TLS configuration
- **NIST 800-88 Rev 1** — media sanitization
- **OCR Audit Protocol** — the 180-control checklist OCR uses
- **HHS Tracking Technologies Bulletin (2024)** — GA / pixel guidance

Industry frameworks (recommended)

- **HITRUST CSF** — superset of HIPAA, audit-certifiable
- **SOC 2 Type II + HIPAA** — common B2B health SaaS combo
- **CIS Controls v8** — practical security baseline
- **OWASP ASVS** — application security verification
- **NIST Cybersecurity Framework (CSF) 2.0** — risk management baseline

Where to file complaints / report breaches

- HHS OCR breach portal: ocrportal.hhs.gov/ocr/breach
- HHS OCR complaint portal: ocrportal.hhs.gov/ocr/smartscreen/main.jsf

Questions?

Discussion · Examples · Edge cases

Reach out before architectural decisions that touch PHI.